Network Security Standards

> **Document Owner:** Security Team | **Status:** Approved | **Last Updated:** February 2026

Overview

This document defines network security standards for the Databricks platform, covering VNet/VPC injection, Private Link/PSC connectivity, IP access controls, encryption, and compliance security profiles. Standards apply across all supported clouds (Azure, AWS, GCP).

Golden Rules

ID	Rule	Severity	WAF Pillar
SEC-01	Production workspaces must use VNet/VPC injection	Critical	Security
SEC-02	Configure Private Link/PSC for control plane access	Critical	Security
SEC-03	Implement IP access lists for workspace access	Required	Security
SEC-04	Use customer-managed keys (CMK) for encryption	Required	Security
SEC-05	Enable diagnostic logging to cloud monitoring	Critical	Security
SEC-06	Configure network egress controls	Required	Security
SEC-07	Use secure cluster connectivity (no public IPs)	Critical	Security
SEC-08	Enable Compliance Security Profile for regulated workloads	Required	Security
SEC-09	Security monitoring and SIEM integration	Required	Security

---

SEC-01: VNet/VPC Injection

Rule

All production workspaces must deploy compute resources into customer-managed virtual networks (Azure VNet, AWS VPC, or GCP VPC).

Why It Matters

- Full control over network routing and security
- Integration with corporate networking infrastructure
- Eliminates public internet exposure for cluster nodes
- Enables custom firewall rules and traffic inspection

Implementation

```
Customer VNet / VPC
├── public-subnet (NAT gateway)
│   └── Databricks control plane connectivity
├── private-subnet (worker nodes)
│   └── Cluster compute resources
└── Security Groups (NSG / AWS SG / GCP Firewall Rules)
    └── Ingress/egress rules
```

Required Subnet Configuration

Subnet	CIDR (minimum)	Purpose
Public	/26 (64 IPs)	Control plane connectivity
Private	/26 (64 IPs)	Worker nodes

Security Group Rules (Minimum)

Direction	Port	Source/Dest	Purpose
Inbound	443	Databricks control plane	Secure cluster connectivity
Outbound	443	Cloud services (Azure/AWS/GCP)	Metastore, storage, APIs
Outbound	3306	Cloud SQL service	Hive metastore (legacy)

SEC-02: Private Link / Private Service Connect

Rule

Configure private connectivity endpoints for control plane access to eliminate public internet transit.

Why It Matters

- All management traffic stays on cloud backbone
- No public IP exposure for workspace access
- Enhanced security for sensitive workloads
- Supports compliance requirements for private connectivity

Architecture

```
User Network
    │
    └── Private Endpoint / Interface Endpoint / PSC Endpoint
            │
            └── Private Link (Azure) / PrivateLink (AWS) / PSC (GCP)
                    │
                    └── Databricks Control Plane (private)
```

Implementation by Cloud

Step	Azure	AWS	GCP
1	Create Private Endpoint	Create VPC Interface Endpoint	Create PSC Endpoint
2	Configure DNS zone (`privatelink.azuredatabricks.net`)	Configure Route 53 / DNS	Configure Cloud DNS
3	Disable public access	Disable public access	Disable public access
4	Test from corporate network	Test from corporate network	Test from corporate network

Verification

```
# Test private endpoint resolution
nslookup myworkspace.azuredatabricks.net    # Azure
nslookup myworkspace.cloud.databricks.com   # AWS / GCP
# Should resolve to private IP (10.x.x.x), not public
```

SEC-03: IP Access Lists

Rule

Configure IP access lists to restrict workspace access to known trusted networks.

Why It Matters

- Additional security layer beyond authentication
- Prevents access from untrusted networks
- Reduces attack surface
- Supports compliance requirements

Configuration

```
{
  "ip_access_lists": [
    {
      "label": "Corporate VPN",
      "list_type": "ALLOW",
      "ip_addresses": ["10.0.0.0/8", "172.16.0.0/12"]
    },
    {
      "label": "Known Threats",
      "list_type": "BLOCK",
```

```
        "ip_addresses": ["192.168.100.0/24"]
      }
    ]
  }
```

Environment Policies

Environment	IP Access Policy
Production	Corporate VPN + known IPs only
Staging	Corporate VPN + CI/CD runners
Development	Corporate VPN (broader)

SEC-04: Customer-Managed Keys (CMK)

Rule

Use customer-managed keys for workspace encryption via your cloud's key management service (Azure Key Vault, AWS KMS, or GCP Cloud KMS).

Why It Matters

- Complete control over encryption key lifecycle
- Supports regulatory compliance (FIPS 140-2)
- Enables key revocation capability
- Provides audit trail for key operations

Implementation Steps

1. **Create key store** (Azure Key Vault / AWS KMS / GCP Cloud KMS) with appropriate protection
2. **Generate or import encryption key** (RSA 2048 minimum)
3. **Configure key rotation policy** (recommended: annual)
4. **Enable CMK for workspace** (during creation or migration)

Key Management Requirements

Setting	Azure Key Vault	AWS KMS	GCP Cloud KMS
Deletion protection	Soft delete + purge protection	Key deletion pending period	Destroy protection
Key type	RSA 2048+	Symmetric or RSA	Symmetric or RSA
Permissions	Get, Wrap, Unwrap	Encrypt, Decrypt, GenerateDataKey	Encrypt, Decrypt

---

SEC-05: Diagnostic Logging

Rule

Enable diagnostic logging to your cloud monitoring service (Azure Monitor, AWS CloudWatch, or GCP Cloud Logging) for all security-relevant events.

Why It Matters

- Centralized security monitoring
- Enables threat detection and investigation
- Supports compliance audit requirements
- Integrates with SIEM systems

Required Log Categories

Category	Description
dbfs	DBFS operations
clusters	Cluster lifecycle
accounts	User/group management
jobs	Job execution
notebook	Notebook operations
workspace	Workspace events
unityCatalog	Data governance events

Implementation by Cloud

Cloud	Monitoring Service	Configuration
Azure	Azure Monitor / Log Analytics	Diagnostic settings on workspace resource
AWS	CloudWatch / S3 delivery	Log delivery configuration in account console
GCP	Cloud Logging / BigQuery	Audit log configuration

SEC-06: Network Egress Controls

Rule

Implement network egress controls to prevent unauthorized data exfiltration.

Why It Matters

- Prevents unauthorized data transfer
- Provides visibility into data movement
- Supports compliance requirements
- Enables detection of anomalous activity

Implementation Options by Cloud

Azure	AWS	GCP
Azure Firewall	AWS Network Firewall	GCP Cloud Firewall
NSG rules	Security Groups	Firewall Rules
NAT Gateway	NAT Gateway	Cloud NAT
UDRs	Route Tables	Custom Routes

Recommended Egress Rules

```
Allow:
├── Cloud storage (blob.core.windows.net / s3.amazonaws.com /
storage.googleapis.com)
├── Databricks services (*.azuredatabricks.net / *.cloud.databricks.com)
├── PyPI/Maven (package managers)
└── Corporate services (specific IPs)

Deny:
└── All other outbound traffic
```

SEC-07: Secure Cluster Connectivity

Rule

Enable secure cluster connectivity (no public IPs) for all production clusters.

Why It Matters

- Eliminates public IP addresses on cluster nodes
- All traffic flows through control plane
- Reduces attack surface significantly
- Simplifies network security management

Verification

```sql
-- Check cluster configuration
SELECT cluster_id, cluster_name,
       single_user_name,
       data_security_mode
FROM system.compute.clusters
WHERE enable_elastic_disk = true;
```

Requirements

- VNet injection enabled
- Outbound connectivity to control plane
- Private Link or secure tunnel for management

SEC-08: Compliance Security Profile

Rule

Enable the Compliance Security Profile (formerly Enhanced Security and Compliance Add-on) for all workspaces processing regulated workloads (HIPAA, PCI-DSS, FedRAMP, SOC 2).

Why It Matters

- Enables industry-specific security controls automatically
- Provides automatic security patching and image hardening (CIS benchmarks)
- Required for compliance certifications in regulated industries
- Applies to all cloud platforms (Azure, AWS, GCP)

When Required

Regulation	Industries	Profile Setting
HIPAA	Healthcare, health insurance	Compliance Security Profile
PCI-DSS	Payment processing, financial services	Compliance Security Profile
FedRAMP	US government contractors	Compliance Security Profile + IL4/IL5
SOC 2 Type II	Any organization in audit scope	Compliance Security Profile

Implementation

1. Contact your Databricks account team to enable the add-on
2. Enable Compliance Security Profile at the workspace level
3. Select applicable compliance standards
4. Verify enhanced monitoring and patching is active

What It Provides

Capability	Description
Image hardening	CIS benchmark-compliant compute images
Automatic patching	Security updates applied without disruption
Enhanced monitoring	Additional audit and compliance logging
Network controls	Stricter default network configurations

SEC-09: Security Monitoring and SIEM Integration

Rule

All production workspaces must forward audit logs and security events to the organization's SIEM system for centralized security monitoring.

Why It Matters

- Centralized security monitoring across all data platform activity
- Enables correlation with other enterprise security events
- Required for SOC 2 and compliance frameworks
- Supports incident response and forensic analysis

Implementation

Cloud	Log Source	SIEM Integration
Azure	Diagnostic Settings	Azure Sentinel, Splunk via Event Hub
AWS	System tables audit logs	Splunk, Datadog via S3/Kinesis
GCP	System tables audit logs	Chronicle, Splunk via Pub/Sub

```sql
-- Create a streaming pipeline to export audit logs
CREATE OR REFRESH STREAMING TABLE security_events AS
SELECT
    event_time,
    service_name,
    action_name,
    identity.email AS user_email,
    source_ip_address,
    request_params
FROM STREAM(system.access.audit)
WHERE action_name IN (
    'createCluster', 'deleteCluster',
    'changePermissions', 'login', 'tokenLogin'
);
```

Security Compliance Add-ons

Enhanced Security and Compliance

For regulated industries (HIPAA, PCI-DSS, SOC 2):

Feature	Description
Compliance security profile	Industry-specific controls
Automatic security updates	Patching without disruption
Enhanced monitoring	Additional audit capabilities

Feature	Description
Image hardening	CIS benchmark compliance

When Required

- Healthcare (HIPAA)
- Financial services (PCI-DSS, SOX)
- Government (FedRAMP)
- Any SOC 2 Type II audit scope

Validation Checklist

Network Architecture

- [ ] VNet injection configured for production
- [ ] Private Link enabled for control plane
- [ ] IP access lists implemented
- [ ] Secure cluster connectivity enabled

Encryption

- [ ] Customer-managed keys configured
- [ ] Key rotation policy in place
- [ ] Key Vault soft delete enabled

Compliance

- [ ] Compliance Security Profile enabled for regulated workloads

Monitoring

- [ ] Diagnostic logging to cloud monitoring (Azure Monitor / CloudWatch / Cloud Logging)
- [ ] SIEM integration configured
- [ ] Security alerts defined

Egress Controls

- [ ] Firewall/NSG rules defined
- [ ] Data exfiltration monitoring enabled
- [ ] Approved egress destinations documented

Quick Reference

```
# Check workspace network configuration
az databricks workspace show --name myworkspace -g mygroup \
  --query "{vnet:parameters.customVirtualNetworkId.value,
privateLink:privateEndpointConnections}"
```

```
# List IP access lists
databricks ip-access-lists list

# Check diagnostic settings
az monitor diagnostic-settings list --resource
/subscriptions/.../workspaces/myworkspace
```

Related Documents

- Platform Overview
- Secrets & Workspace Management
- Unity Catalog Governance

References

- Well-Architected Lakehouse: Security
- Databricks Security Guide
- Network Security
- Private Connectivity
- IP Access Lists
- Compliance Security Profile